

Event Information:

EventID :

214

Event Time :

Jan, 01, 2024, 12:37 PM

Rule :

SOC251 - Quishing Detected (QR Code Phishing)

Level :

Security Analyst

SMTP Address :

158.69.201.47

Source Address :

security@microsecmfa.com

Destination Address :

Claire@letsdefend.io

E-mail Subject :

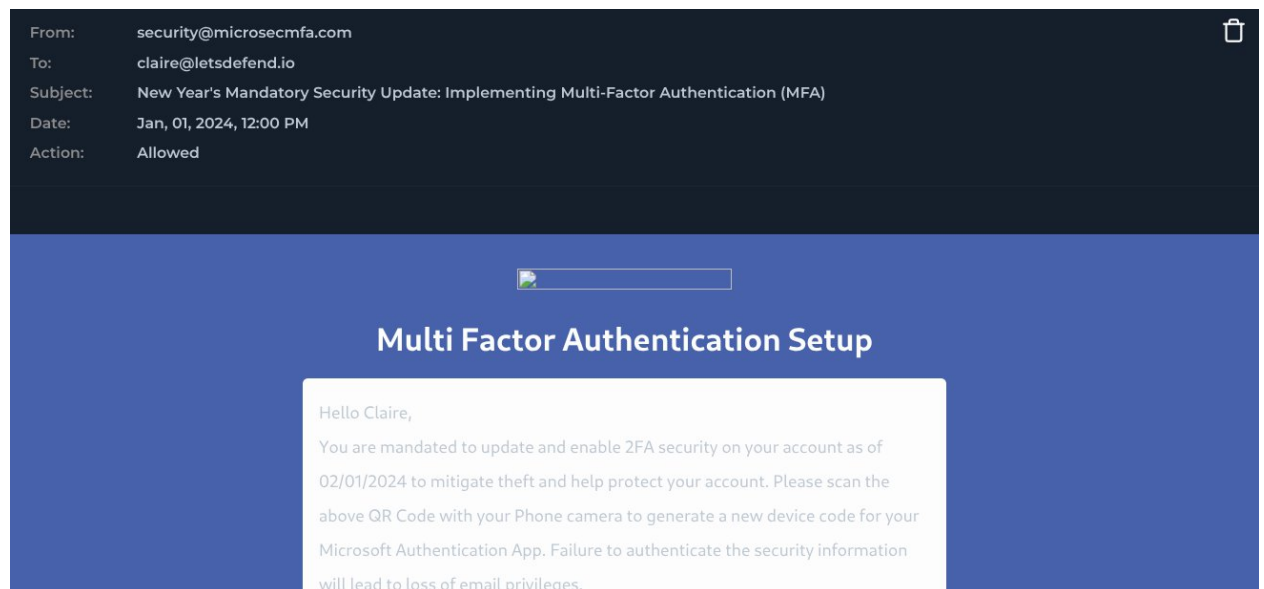
New Year's Mandatory Security Update: Implementing Multi-Factor Authentication (MFA)

Device Action :

Allowed

Analysis Steps:

Email logs were searched for the email that triggered the alert. Immediately we can spot a source email which is attempting to pose as a legitimate Microsoft email.

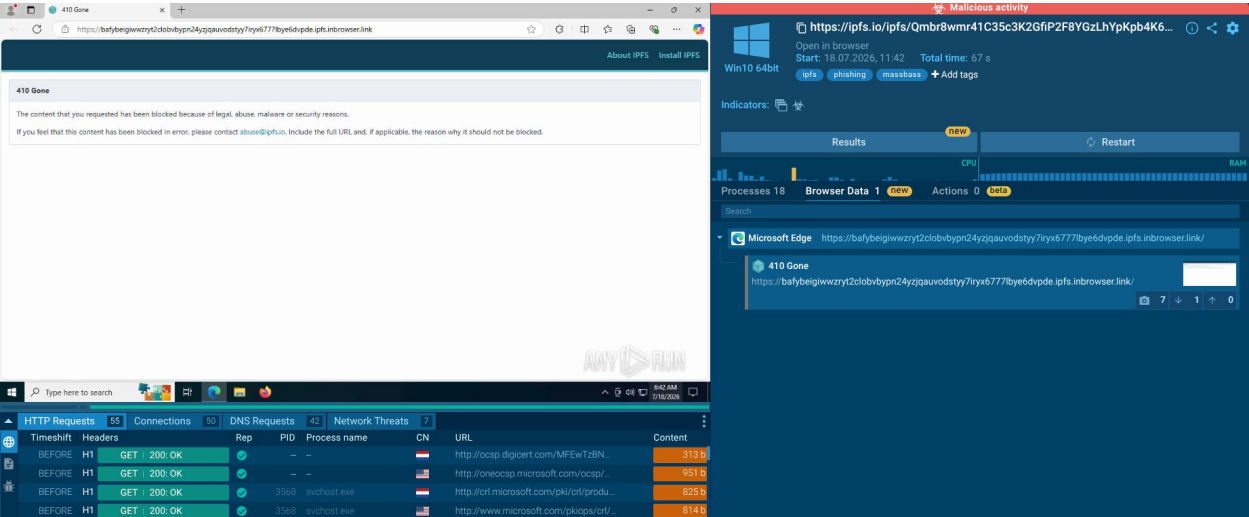


The QR code was then analysed using zbar's zbarimg utility to obtain the link.

```
QR-Code:https://ipfs.io/ipfs/Qmbr8wmr41C35c3K2GfiP2F8YGzLhYpKpb4K66KU6mLmL4#
scanned 1 barcode symbols from 1 images in 0.01 seconds
```

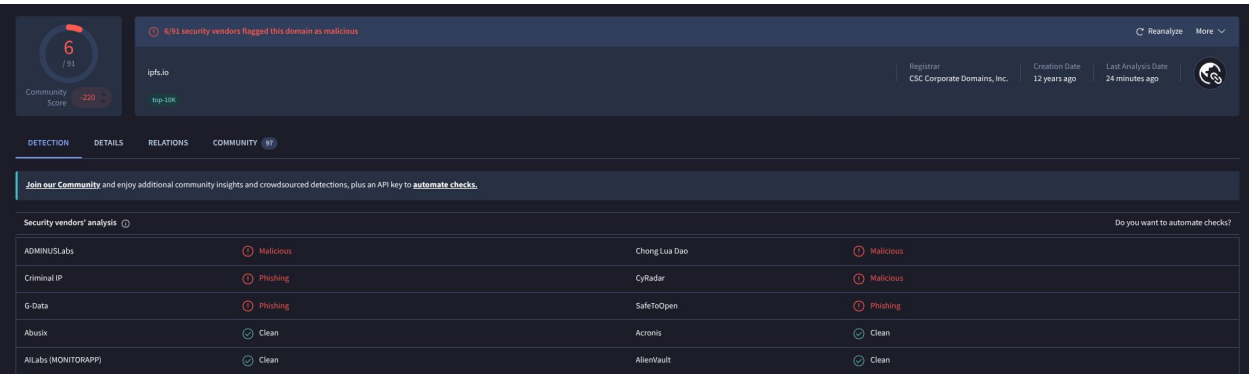
```
hxxps://ipfs[.]io/ipfs/Qmbr8wmr41C35c3K2GfiP2F8YGzLhYpKpb4K66KU6mLmL4#
```

On analysing the URL via AnyRun it appears that the website has been taken down.

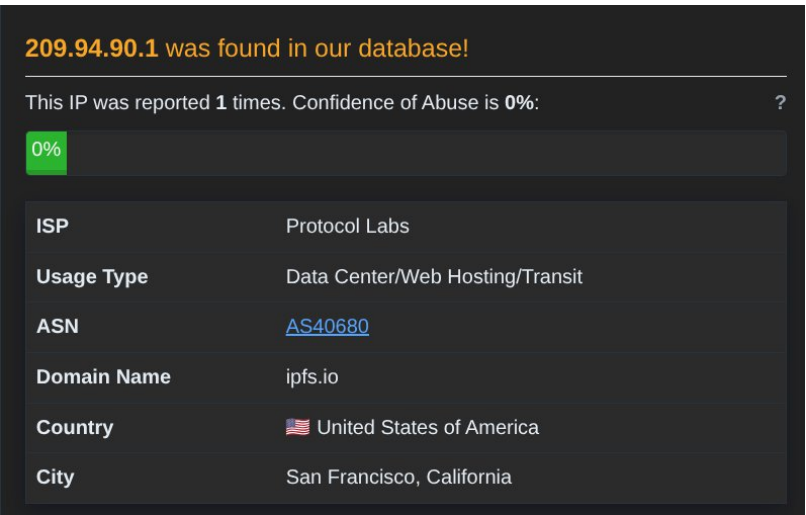


When searching the network logs for the malicious website URL no results are found. It is still possible that an employee may have scanned the QR code on a personal device.

ipfs[.]io is not in our CTI database and is external to the organisation. VirusTotal indicates 6/91 security vendors flagged it as malicious.



On AbuseIPDB this IP was reported 1 time with a 0% confidence of abuse.



Based on following Playbook procedure and the analysis of available information, this alert is determined to be a True Positive.

Report:

Incident Summary

Analysis confirms a True Positive Quishing (QR Code Phishing) attempt targeting an internal user. A threat actor spoofed a mandatory Microsoft MFA update to trick the user into scanning a malicious QR code. The embedded link directed to a decentralised IPFS gateway hosting malicious content, which has since been taken down by the provider for abuse. Network telemetry indicates the link was not accessed from a corporate device.

Incident Details

- **Alert Name:** SOC251 - Quishing Detected (QR Code Phishing)
- **Target Account:** claire[.]letsdefend[.]io
- **Sender Address:** security[.]microsecmfa[.]com
- **Email Subject:** New Year's Mandatory Security Update: Implementing Multi-Factor Authentication (MFA)
- **Device Action:** Allowed

Analysis and Evidence

- **Social Engineering:** The email utilised a false sense of urgency, claiming the user would lose email privileges if they did not scan the provided QR code to update their 2FA security.
- **Payload Extraction:** The QR code was safely isolated and decoded using the zbarimg utility. The extracted payload was the URL:
hxxps://ipfs[.]io/ipfs/Qmbr8wmr41C35c3K2GfiP2F8YGzLhYpKpb4K66KU6mLmL4#.
- **Execution Verification:** Network logs were queried for the extracted URL and its associated IP infrastructure; no matching traffic was found. This indicates the QR code was either not scanned, or scanned on a personal, unmonitored mobile device.
- **Sandbox Analysis:** Analysis of the URL via AnyRun resulted in a "410 Gone" HTTP error, accompanied by a warning that the requested content was blocked due to abuse, malware, or security reasons.

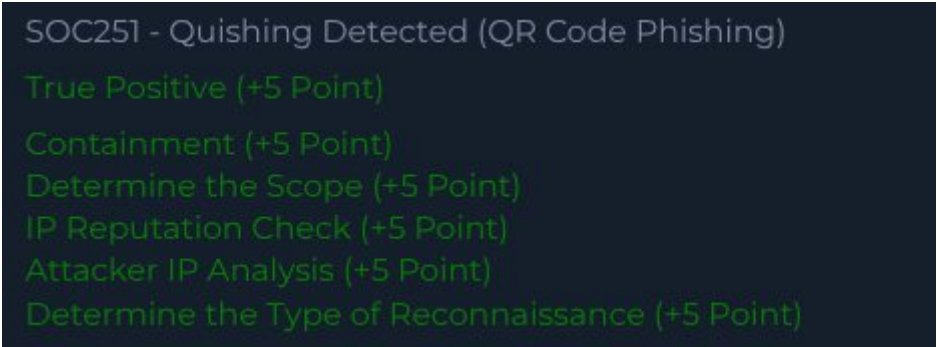
Threat Intelligence

- **OSINT (Infrastructure):** The domain ipfs[.]io is external to the organisation and acts as a gateway for the InterPlanetary File System, which is frequently abused by threat actors to host phishing sites. VirusTotal indicates 6/91 security vendors flag the domain as malicious. The resolving IP (209[.]94.90.1) was reported once on AbuseIPDB with a 0% confidence score.

Actions Taken

1. Analysed the suspicious email and safely decoded the embedded QR code using zbarimg.
2. Investigated the extracted URL in a secure sandbox, confirming it was associated with malicious activity and had been taken down.
3. Searched internal network logs and confirmed no corporate devices accessed the malicious IPFS link.
4. Purged the phishing email from the user's inbox to prevent any future interaction.
5. Contained the device until it can be determined whether corporate credentials were utilised.
6. Declared the alert a True Positive and closed the ticket.

Let's Defend Result



```
SOC251 - Quishing Detected (QR Code Phishing)
True Positive (+5 Point)
Containment (+5 Point)
Determine the Scope (+5 Point)
IP Reputation Check (+5 Point)
Attacker IP Analysis (+5 Point)
Determine the Type of Reconnaissance (+5 Point)
```